



SEGURANÇA DA INFORMAÇÃO

INTRODUÇÃO

É consenso que a segurança da informação ocupa uma posição estratégica nas organizações e instituições, conforme defendido por Landin et al. (2025, p. 8397):

A segurança digital tem se tornado um dos pilares essenciais no contexto atual, à medida que a sociedade avança para um mundo conectado. Com a crescente digitalização de processos e a interdependência entre sistemas, a proteção das informações torna-se fundamental para garantir a integridade, a confidencialidade e a disponibilidade dos dados.

Em meio à expansão de plataformas tecnológicas, como sistemas baseados em nuvem, aplicações móveis, serviços web e infraestruturas de internet das coisas, a superfície de exposição a riscos cibernéticos também se expande, revelando vulnerabilidades estruturais e operacionais que desafiam os modelos tradicionais de proteção.

Lima (2023, p. 12) defende que

é fundamental abordar ameaças em todas as áreas da organização, utilizando modelos coerentes. Isso envolve analisar os riscos em cada área e envolver todas as partes interessadas, garantindo comprometimento e participação ativa.

Nesse contexto, compreender a dinâmica entre plataformas digitais e os ataques cibernéticos que as ameaçam não é apenas uma exigência técnica, mas uma necessidade crítica para a formulação de políticas robustas de defesa e continuidade de negócios.

Examinar, de forma integrada, os fundamentos da segurança em plataformas digitais, os vetores e métodos de ataque mais recorrentes, os mecanismos de defesa possíveis e as implicações legais e organizacionais da gestão da segurança é a proposta deste tema, que não se restringe à dimensão técnica.

TEMA 1 – FUNDAMENTOS DA SEGURANÇA EM PLATAFORMAS DIGITAIS

A compreensão dos fundamentos da segurança em plataformas digitais é o primeiro passo para que o profissional da área possa atuar com consistência diante dos desafios que marcam a era da hiperconectividade. As plataformas contemporâneas, sejam aplicações web, ambientes móveis, sistemas em nuvem ou dispositivos de Internet das Coisas, constituem

infraestruturas críticas para o funcionamento de organizações públicas, privadas e governamentais (Santos; Krawszuk, 2020). Nesse cenário, qualquer vulnerabilidade em seus componentes ou fluxos de dados pode resultar em impactos significativos sobre integridade, disponibilidade e confidencialidade das informações.

1.1 Conceitos e arquitetura de plataformas (web, móvel, nuvem, IoT)

Segundo Oliveira, Carelli e Grillo (2020), plataformas digitais englobam ambientes diversos, como aplicações web, dispositivos móveis, sistemas em nuvem e ecossistemas de internet das coisas (IoT), cada qual com suas particularidades arquitetônicas e desafios singulares.

A arquitetura de segurança, neste contexto, se manifesta como uma estrutura integrativa que combina políticas, controles técnicos e procedimentos, visando proteger os ativos digitais em múltiplas camadas. Tal arquitetura contempla camadas físicas, de rede, aplicação e dados, implementando mecanismos como firewalls, sistemas de detecção e prevenção de intrusão (IDS/IPS), autenticação multifator e criptografia, entre outros, conforme explana Silva e Cunha (2005, p. 16) “distribuída, portátil, escalonável e ainda tendo capacidade de prover e requisitar serviços, ou seja, troca de informações entre aplicações.” Este modelo defendido como “defesa em profundidade” assegura que, mesmo diante do comprometimento de uma camada, outras protejam os recursos críticos da plataforma, ampliando a resiliência contra-ataques cibernéticos.

Além disso, a natureza distribuída e heterogênea desses ambientes, especialmente nuvem e IoT, exige abordagens arquitetônicas personalizadas que considerem particularidades como a mobilidade, a variabilidade de dispositivos e a complexidade das comunicações, sem perder de vista os princípios fundamentais da segurança.

1.2 Superfície de ataque e avaliação de riscos em ambientes distribuídos

A superfície de ataque refere-se ao conjunto de pontos vulneráveis por meio dos quais agentes maliciosos podem tentar comprometer um sistema. Em plataformas digitais modernas, caracterizadas pela descentralização e heterogeneidade, com múltiplas interfaces, sensores, APIs e conexões

remotas, essa superfície se expande significativamente, exigindo um mapeamento rigoroso para a correta priorização dos riscos (Silva; Cunha, 2005).

A avaliação de riscos, no contexto desses ambientes distribuídos, deve transcender a mera listagem de vulnerabilidades, integrando análise qualitativa e quantitativa que contemple fatores como o valor dos ativos, as ameaças potenciais, as vulnerabilidades existentes e o impacto esperado de uma exploração. Ferramentas e metodologias consolidadas, como a análise baseada em CVSS (Common Vulnerability Scoring System), e frameworks como Octave e Fair, fornecem subsídios para esta atividade crítica (Singh; Josh, 2018).

Este enfoque estratégico orienta a alocação eficiente de recursos para mitigação, busca minimizar o impacto operacional e permite a adaptação contínua do sistema diante do dinamismo dos vetores de ameaça, com especial atenção a novas formas de ataque que emergem no contexto da nuvem, mobilidade e IoT.

1.3 Princípios de segurança em múltiplas camadas (defesa em profundidade)

O princípio da defesa em profundidade é basilar para a arquitetura de segurança em plataformas digitais. Trata-se da implementação coordenada e sobreposta de controles técnicos, administrativos e físicos que estabelecem barreiras sucessivas contra-ataques.

[ Suspicious Content] A adoção de múltiplas camadas de controle contribui significativamente para a mitigação de falhas críticas, uma vez que o comprometimento de uma camada pode ser detectado, contido e neutralizado antes de gerar impactos irreversíveis. Conforme Bloch e Barros (2011), essa abordagem inclui a implementação de políticas rigorosas de controle de acesso e autenticação robusta, assegurando que apenas usuários autorizados acessem os recursos; a criptografia de dados em trânsito e em repouso, garantindo confidencialidade e integridade; o monitoramento contínuo aliado a sistemas de detecção de anomalias e intrusões, que favorecem respostas proativas; e a segmentação e microsegmentação de redes, limitando a movimentação lateral de ameaças no ambiente.

Essa abordagem assume especial relevância diante dos ambientes modernos, nos quais a superfície de ataque é ampla e a dinâmica das ameaças é veloz. A defesa em profundidade deve, portanto, ser acompanhada por processos ágeis de atualização, auditoria e testes de segurança.

1.4 Políticas básicas de proteção e modelos de governança de plataforma

A sustentação da segurança efetiva em plataformas digitais perpassa a adoção de políticas claras, processos bem definidos e modelos de governança robustos que coordenam pessoas, tecnologias e processos (Albuquerque; Ribeiro, 2002; Lyra, 2017). Políticas básicas incluem diretrizes para controle de acesso, gestão de identidades, proteção de dados, uso aceitável dos recursos, resposta a incidentes e conformidade regulatória.

A governança de segurança da informação garante que tais políticas sejam continuamente revisadas, cumpridas e alinhadas aos objetivos estratégicos da organização, integrando aspectos como sugere Teixeira (2023):

- responsabilidade e atribuições claras no gerenciamento da segurança;
- avaliação e mitigação contínua dos riscos;
- capacitação e conscientização dos usuários;
- monitoramento, auditoria e conformidade legal, especialmente considerando legislações como a LGPD e GDPR.

Modelos de governança como Cobit e Itil oferecem frameworks auxiliares para estruturar essas atividades, facilitando a articulação entre os níveis estratégico, tático e operacional. Essa perspectiva sistêmica é crucial para que a segurança transcenda a mera implementação técnica, consolidando-se como elemento central da gestão organizacional.

A reflexão sobre os fundamentos da segurança nas plataformas digitais deve, pois, orientar a construção de ambientes que não apenas resistam, mas antecipem e aprendam com as ameaças, sustentando a confiança digital necessária para a operação moderna.

TEMA 2 – CIBERATAQUES: VETORES, TÉCNICAS E EXPLORAÇÃO DE VULNERABILIDADES

A proteção de plataformas só se torna eficaz quando há um profundo entendimento sobre o funcionamento, a origem e a evolução dos ataques cibernéticos. Compreender o adversário é uma premissa essencial na construção de defesas eficazes. De acordo com Cano (2020, p. 69), a finalidade de um ciberataque é “causar incerteza no modelo de segurança de uma organização ou nação ou expressando de forma mais prática, revelar os pontos cegos e ocultos nas implementações de segurança que as empresas e nações têm”.

Ataques como phishing, injeção de código, negação de serviço distribuída (DDoS) e ransomware revelam não apenas fragilidades técnicas, mas também deficiências culturais, organizacionais e educacionais (Cano, 2020; Nunes et al., 2024). Além de mapear essas ameaças, este tema convida à reflexão sobre as condições que favorecem a atuação de cibercriminosos, bem como os mecanismos de mitigação que exigem constante atualização e vigilância.

2.1 Tipos e classificações de ataques cibernéticos (técnicos, humanos e lógicos)

Os ataques cibernéticos podem ser categorizados conforme a natureza do vetor empregado, sendo geralmente classificados como técnicos, humanos ou lógicos. Os ataques técnicos caracterizam-se pela exploração direta de vulnerabilidades em sistemas computacionais, envolvendo ações como execução de malware, injeção de código malicioso e ataques de força bruta para a quebra de senhas. São, em geral, automatizados e propagados em larga escala por meio de scripts ou softwares especializados.

Por sua vez, os ataques humanos estão fundamentados em técnicas de engenharia social, cujo foco está na manipulação psicológica dos usuários para extração de informações sensíveis. Exemplos recorrentes incluem campanhas de phishing (por e-mail, SMS ou chamadas telefônicas) e spear phishing, que têm como alvo perfis específicos, explorando a confiança e a desatenção das vítimas.

Já os ataques classificados como lógicos exploram o comportamento programado de aplicações ou sistemas, valendo-se de manipulação de URLs, execução não autorizada de comandos e inserção de backdoors para garantir acesso persistente, ainda que dissimulado, ao ambiente comprometido.

2.2 Vetores clássicos e modernos (malware, ransomware, phishing, DDoS)

Entre os vetores de ataque mais empregados na atualidade destaca-se o malware, termo que engloba toda categoria de software malicioso como vírus, trojans, spyware e worms, desenvolvido com o intuito de infiltrar-se em sistemas computacionais para roubar dados, causar danos ou explorar recursos sem autorização (Nunes et al., 2024; Lyra, 2017). A persistência desse vetor como meio inicial de comprometimento revela sua adaptabilidade e potencial destrutivo.

O ransomware representa uma modalidade específica de malware cuja função principal é criptografar arquivos e sistemas, exigindo pagamento para sua liberação. Tem sido responsável por severos impactos em organizações públicas e privadas, com paralisações operacionais e prejuízos financeiros significativos.

Outro vetor amplamente explorado é o phishing, que consiste em comunicações fraudulentas, muitas vezes simulando entidades legítimas, com o objetivo de obter credenciais, informações bancárias ou dados confidenciais das vítimas.

Os ataques DDoS (Distributed Denial of Service), por sua vez, ocorrem quando múltiplos dispositivos são utilizados para gerar tráfego artificial e massivo, sobrecarregando servidores e tornando aplicações ou serviços indisponíveis para seus legítimos usuários. Vetores mais recentes também incluem a exploração de APIs, dispositivos IoT, redes sociais e aplicativos móveis como canais de disseminação de ameaças.

2.3 Vulnerabilidades comuns em aplicações web e móveis (Owasp Top 10)

O projeto Owasp Top 10 constitui uma referência global na identificação e classificação das principais vulnerabilidades em aplicações web e móveis. Na versão de 2025, destacam-se falhas como a quebra de controle de acesso

(Broken Access Control), que permite que usuários não autorizados acessem funcionalidades ou dados restritos.

Outro ponto crítico refere-se às falhas de criptografia, muitas vezes oriundas de implementações inadequadas ou uso indevido de algoritmos, comprometendo a confidencialidade de dados sensíveis. A injeção de código (SQL, NoSQL etc.), ainda amplamente observada, permite a execução de comandos arbitrários por invasores.

A presença de projetos arquitetonicamente inseguros (Insecure Design) aumenta a superfície de ataque desde a concepção do sistema. Além disso, destaca-se a exposição de dados sensíveis por meio de armazenamento ou transmissão inseguros e as desconfigurações de servidores e APIs, como ocorre em ataques SSRF (Server-Side Request Forgery), que possibilitam acesso a recursos internos não autorizados.

A mitigação dessas vulnerabilidades exige práticas de desenvolvimento seguro, validação contínua do código e a aplicação sistemática de testes e auditorias especializadas.

2.4 Escalonamento de privilégios e persistência em sistemas comprometidos

O escalonamento de privilégios é uma técnica comum entre agentes maliciosos e consiste na obtenção de maiores permissões dentro do ambiente comprometido após um acesso inicial restrito. Esse escalonamento pode ser vertical, quando o invasor adquire direitos administrativos, ou horizontal, ao acessar recursos de outros usuários com o mesmo nível hierárquico. Tal prática permite a manipulação de configurações críticas, instalação de ferramentas ocultas e comprometimento estrutural do sistema.

A persistência, por sua vez, refere-se à capacidade do invasor de manter o acesso contínuo mesmo após reinicializações ou tentativas de mitigação. Isso é viabilizado por meio da criação de backdoors, execução de serviços disfarçados ou uso de contas administrativas não monitoradas. Tais mecanismos são cruciais para a exfiltração prolongada de dados, movimentações laterais em redes corporativas ou ações de sabotagem silenciosa.

A detecção precoce dessas atividades exige o uso de ferramentas de monitoramento em tempo real, políticas de hardening e análise de comportamento para identificação de anomalias nos fluxos de acesso.

TEMA 3 – ARQUITETURA SEGURA E PROTEÇÃO DE AMBIENTES OPERACIONAIS

Nenhuma política de segurança se sustenta sem uma arquitetura sólida que considere tanto os sistemas operacionais quanto os ambientes de execução das aplicações (Ferreira; Araújo, 2008). Este tema se centra nas estratégias de hardening de servidores e estações de trabalho, nas boas práticas de desenvolvimento seguro e na segurança em ambientes modernos, como containers, orquestradores e serviços em nuvem.

Diante da crescente adoção de microserviços, APIs abertas e infraestrutura como código, o desafio de proteger o ciclo de vida das aplicações se intensifica. Essa realidade exige o domínio de princípios de secure coding, o uso consciente de ferramentas de análise de código e a vigilância constante sobre configurações e permissões. Ao abordar essas práticas, o objetivo é levar o discente à compreensão de que a segurança não é um adendo ao desenvolvimento ou à operação, mas sim um princípio estruturante que deve ser incorporado desde a concepção até o descarte de qualquer sistema digital.

3.1 Segurança em sistemas operacionais (hardening e configurações seguras)

Para Mourad, Laverdière e Debbabi (2008), o hardening de sistemas operacionais representa um pilar indispensável para a redução da superfície de ataque e para o fortalecimento da defesa perimetral e interna das plataformas. Consiste em um

reforço da segurança de software como qualquer processo, metodologia, produto ou combinação destes que é usado para adicionar funcionalidades de segurança e/ou remover vulnerabilidades ou impedir sua exploração em software existente. (Mourad; Laverdière; Debbabi, 2008, p. 60)

Lyra (2017) e Ferreira e Araújo (2008) convergem enquanto estabelecer configurações seguras por meio da minimização de serviços ativos, remoção de componentes desnecessários, aplicação contínua de patches e correções,

restrição de permissões e implantação de políticas rígidas de autenticação e auditoria.

Os sistemas modernos, sejam servidores ou estações de trabalho, demandam configurações que acompanhem tanto padrões internacionais quanto às especificações técnicas do fornecedor do sistema. Além disso, conforme alertam Ibor e Obidinnu (2015), mecanismos de auditoria devem garantir o monitoramento em tempo real de eventos suspeitos, contribuindo para a resposta rápida e eficaz a incidentes.

A segurança do sistema operacional forma a base para a proteção de todo o ambiente, sendo essencial que empresas adotem frameworks de hardening reconhecidos, alinhados às diretrizes de segurança da informação e conformidade regulatória, minimizando vulnerabilidades exploráveis por agentes maliciosos.

3.2 Ambientes de aplicação: segurança em APIs, containers e microsserviços

A popularização dos modelos de arquitetura baseados em microsserviços e containers transformou positivamente a agilidade e escalabilidade das aplicações, porém introduziu desafios singulares de segurança. Para He et al. (2022), APIs abertas, responsáveis pela comunicação entre esses serviços, representam vetores de risco que exigem rigorosos controles de autenticação, autorização e monitoramento, preferencialmente baseados em princípios Zero Trust e na proteção de dados sensíveis.

No tocante a containers e orquestradores (como Kubernetes), a segurança deve contemplar o ciclo completo do ambiente: desde a composição da imagem (image scanning, assinatura digital) até a configuração do runtime e políticas de acesso, incluindo o isolamento entre containers para evitar movimentos laterais e a implementação de políticas de rede restritivas. A gestão adequada dos segredos (como chaves e tokens de acesso) e a adoção de práticas automatizadas para validação e conformidade, por meio de ferramentas integradas a pipelines CI/CD, são essenciais para minimizar riscos operacionais e de desenvolvimento.

A mutabilidade e efemeridade desses ambientes, para He et al. (2020), demandam também soluções para detecção e resposta automatizada a anomalias, considerando o ritmo acelerado das implantações e atualizações. A segurança em ambientes de microsserviços, portanto, exige a união entre governança, automação e visibilidade, alinhados às melhores práticas de mercado.

3.3 Desenvolvimento seguro (secure coding) e validação de entrada

A segurança incorporada ao código-fonte das aplicações, a partir do desenvolvimento seguro (secure coding), é componente vital para evitar vulnerabilidades que podem ser exploradas na produção. Este paradigma recomenda práticas sistemáticas de identificação, prevenção e correção de falhas durante as fases de design, codificação e teste.

Fundamentalmente, a validação rigorosa das entradas (input validation) protege contra ataques clássicos, como injeção de comandos (SQL Injection, Command Injection), Cross-Site Scripting (XSS) e outras explorações que decorrem da manipulação indevida de dados fornecidos por usuários ou sistemas externos, conforme defende Slavin (2025).

Ferramentas automáticas de análise estática e dinâmica do código, assim como revisão por pares e testes de penetração orientados, compõem o arsenal necessário para garantir a qualidade e segurança do software.

Adotar bibliotecas seguras, seguir padrões de codificação reconhecidos e educar equipes para a cultura de segurança constituem aspectos complementares para a efetividade do desenvolvimento seguro. Em ambientes com ciclos ágeis e DevOps, o shift-left na segurança fortalece a detecção precoce e diminui custos e riscos associados às vulnerabilidades exploradas na produção, conforme proposto por Rajapakse, Zahedi, Babar e Shen (2021).

TEMA 4 – TESTES, MONITORAMENTO E RESPOSTA A INCIDENTES

Mesmo as melhores defesas estão sujeitas a falhas. Por isso, a capacidade de detectar, reagir e aprender com incidentes torna-se elemento vital na resiliência organizacional frente as ameaças cibernéticas. Este módulo trata das técnicas de testes de segurança (pentests), análise de

vulnerabilidades, monitoramento de redes e sistemas, bem como dos protocolos de resposta a incidentes.

Ferramentas como Siem, IDS/IPS e honeypots são abordadas como instrumentos fundamentais de visibilidade e reação. Além disso, conforme cita Veerasamy (2009), a composição e atuação de equipes especializadas (Red Team, Blue Team e Purple Team) são discutidas dentro do escopo de simulações realistas e dinâmicas ofensivas-defensivas. Mais do que executar ações técnicas, este tema propõe uma reflexão sobre a maturidade organizacional no enfrentamento de crises, a importância do tempo de resposta, e a necessidade de integrar inteligência cibernética à cultura institucional.

4.1 Técnicas de pentest, análise de vulnerabilidades e auditorias de segurança

Os testes de penetração (pentests) representam uma abordagem proativa e controlada de simulação de ataques reais com o objetivo de identificar vulnerabilidades exploráveis antes que agentes maliciosos o façam. Estudos como o de Zhang, Xing e Li (2025) e a revisão sistemática de Taxonomy (2023) demonstram que essas análises, aliadas às auditorias de segurança, permitem examinar tanto falhas técnicas quanto lacunas processuais, fortalecendo a resiliência cibernética organizacional.

Complementarmente, a análise de vulnerabilidades, conforme descrita por Bi et al. (2023), utiliza scanners automatizados e técnicas de avaliação para mapear falhas conhecidas, como versões desatualizadas de softwares e configurações inseguras. A integração entre auditorias periódicas e testes regulares estabelece um ciclo virtuoso de melhoria contínua, norteado pela priorização de riscos e pela vigilância de ameaças emergentes.

4.2 Ferramentas de exploração e defesa (Metasploit, Wireshark, Nmap, Burp Suite)

Ferramentas como o Metasploit desempenham funções ofensivas e defensivas: permitem simular ataques reais e analisar possíveis vetores de exploração. Nmap é amplamente utilizado para mapeamento de redes, identificando hosts ativos e portas abertas, enquanto Wireshark realiza a

captura e análise detalhada do tráfego de rede, sendo fundamental para identificação de anomalias em tempo real (Zhang et al., 2025).

Burp Suite constitui um framework robusto para testes em aplicações web, com recursos que abrangem desde a interceptação de tráfego até a análise automatizada de vulnerabilidades. O domínio dessas ferramentas é essencial para estratégias realistas de pentest e inspeção de sistemas, segundo a Taxonomy (2023).

4.3 Monitoramento com ferramentas Siem e detecção de intrusos (IDS/IPS)

O monitoramento contínuo é o componente central da detecção e resposta a ameaças. De acordo com o NIST SP 800-94, sistemas de Gerenciamento de Informações e Eventos de Segurança (Siem) consolidam dados oriundos de diversas fontes, facilitando a correlação de incidentes. Sistemas de detecção de intrusão (IDS) e de prevenção (IPS) monitoram atividades de rede e bloqueiam ataques em tempo real, conforme políticas predefinidas (Coulibaly, 2020).

Essas tecnologias, integradas a equipes especializadas, ampliam a visibilidade sobre as operações e reforçam a segurança de forma responsiva e preventiva.

4.4 Resposta a incidentes: planos, equipes, comunicação e recuperação

A resposta a incidentes depende de planos estruturados e de equipes capacitadas para executar processos de identificação, contenção, erradicação e recuperação. O Nist SP 800-137 estabelece diretrizes para o monitoramento contínuo e a resposta efetiva, enfatizando a importância da comunicação transparente com stakeholders e da conformidade com obrigações legais.

TEMA 5 – CONFORMIDADE, TENDÊNCIAS E ESTUDOS DE CASO

A evolução da segurança da informação está intrinsecamente ligada às transformações sociais, legais e tecnológicas que moldam o ecossistema digital contemporâneo. Normas técnicas e regulamentações legais como ISO/IEC 27001, LGPD, GDPR e os frameworks do Nist e CIS não apenas orientam boas

práticas como também impõem responsabilidades jurídicas e éticas às organizações (Singh; Bharti; Hooda, 2021; Attackiq, 2021). Este tema busca conectar a prática da segurança à sua dimensão normativa e prospectiva. Discutem-se ainda ameaças emergentes, como o uso malicioso da inteligência artificial, o crescimento do ransomware-as-a-service e a insegurança em sistemas de IoT e blockchain (Willie, 2025; Xu et al., 2024).

5.1 Normas e frameworks: ISO/IEC 27001, 27002, Nist, CIS Controls, Mitre ATT&CK

As normas ISO/IEC 27001 e 27002 representam referências internacionais básicas para a gestão da segurança da informação. A primeira estabelece os requisitos para um Sistema de Gestão da Segurança da Informação (SGSI), enquanto a segunda detalha controles recomendados para implementação, incluindo governança, avaliação de riscos e proteção de ativos. Juntamente com essas, frameworks como o Nist Cybersecurity Framework e os CIS Controls oferecem diretrizes operacionais e técnicas que auxiliam na estruturação e maturação das políticas de segurança (Singh; Bharti; Hooda, 2021).

Por sua vez, o Mitre ATT&CK constitui um catálogo sistematizado de táticas e técnicas utilizadas por adversários cibernéticos, valioso para o desenvolvimento de defesas mais assertivas e para o alinhamento de estratégias de detecção e resposta (Attackiq, 2021). A integração desses instrumentos normativos e ferramentas propicia um ambiente de segurança coerente, auditável e resiliente, capaz de adaptar-se às constantes mudanças e ameaças no cenário digital.

5.2 Legislação aplicável: LGPD, GDPR, Marco Civil da Internet

Do ponto de vista legal, a conformidade com regulamentações como a Lei Geral de Proteção de Dados (LGPD) (Brasil, 2018), o Regulamento Geral sobre a Proteção de Dados (GDPR) e o Marco Civil da Internet no Brasil impõe obrigações rigorosas relativas à proteção, tratamento e responsabilização no uso de dados pessoais. Essas legislações refletem uma crescente preocupação social com a privacidade e os direitos dos titulares, estabelecendo fundamentos para a transparência, segurança e governança de dados.

No contexto de 2025, essas normas vêm se fortalecendo com a ampliação da fiscalização, aumento das penalidades e a exigência de mecanismos técnicos e administrativos robustos, como controle de acesso granular, auditoria contínua e relato transparente de incidentes. A regulamentação cobre não apenas as organizações titulares dos dados, mas também suas cadeias de fornecedores, ampliando o escopo de responsabilidade e impactando profundamente as arquiteturas de segurança e gestão de riscos.

5.3 Ameaças emergentes: ransomware-as-a-service, inteligência artificial maliciosa, ataques a IoT e blockchain

O panorama contemporâneo evidencia a emergência de ameaças cada vez mais sofisticadas e amplamente disseminadas. Destaca-se o Ransomware-as-a-Service (RaaS), modelo que democratiza o acesso às ferramentas maliciosas, permitindo que agentes com menor conhecimento técnico realizem ataques devastadores mediante pagamento a operadores especializados (Willie, 2025).

Outra frente crítica é o uso malicioso da inteligência artificial (IA), tanto na automatização de ataques como na criação de deepfakes, manipulação comportamental e evasão de mecanismos tradicionais de defesa. Isso impõe a urgente necessidade de desenvolvimento e implementação de contramedidas baseadas também em IA para detecção e resposta (Xu et al., 2024; Jadhav; Mahule; Sontakke, 2025).

Ademais, o ataque a ecossistemas envolvendo IoT e tecnologias blockchain enfatiza vulnerabilidades específicas decorrentes da dispersão, heterogeneidade e natureza muitas vezes imutável dos dados. Dispositivos IoT frequentemente apresentam falhas de configuração e baixa capacidade de proteção, enquanto blockchains, apesar da segurança criptográfica intrínseca, enfrentam riscos nas camadas de aplicação, como contratos inteligentes vulneráveis (Jadhav; Mahule; Sontakke, 2025).

REFERÊNCIAS

- ABNT. Associação Brasileira de Normas Técnicas. **NBR ISO/IEC 27001:2022** — Tecnologia da informação — Segurança da informação — Sistemas de gestão de segurança da informação — Requisitos. Rio de Janeiro: ABNT, 2022.
- ABNT. Associação Brasileira de Normas Técnicas. **NBR ISO/IEC 27002:2023** — Tecnologia da informação — Segurança da informação — Controles de segurança da informação. Rio de Janeiro: ABNT, 2023.
- BI, Y. et al. Benchmarking software vulnerability detection techniques: a survey. **arXiv**, 2023. Disponível em: <<https://arxiv.org/abs/2303.16362>>. Acesso em: 21 ago. 2025.
- BLOCH, M.; BARROS, J. **Physical-layer security: from information theory to security engineering**. Cambridge University Press, 2011.
- BRASIL. Lei nº 12.965, de 23 de abril de 2014. Marco Civil da Internet. **Diário Oficial da União**, seção 1, Brasília, DF, p. 1, 24 abr. 2014.
- BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Dispõe sobre a proteção de dados pessoais e altera a Lei nº 12.965, de 23 de abril de 2014 (Marco Civil da Internet). **Diário Oficial da União**, seção 1, Brasília, DF, ano 155, n. 157, p. 1–4, 15 ago. 2018. Disponível em: <https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/L13709.htm>. Acesso em: 21 ago. 2025.
- CANO, J. J. Ciberataques. **Revista Sistemas**, n. 157, p. 67-74, 2020.
- CIS Controls v8. **Center for Internet Security**. 2021. Disponível em: <<https://www.cisecurity.org/controls/cis-controls-list>>. Acesso em: 21 ago. 2025.
- COULIBALY, K. An overview of intrusion detection and prevention systems. **arXiv**, 2020. Disponível em: <<https://arxiv.org/abs/2004.08967>>. Acesso em: 21 ago. 2025.
- HE, Y. et al. A survey on zero trust architecture: challenges and future trends. **Wireless Communications and Mobile Computing**, v. 2022, n. 1, p. 6476274, 2022.

IBOR, A. E.; OBIDINNU, J. N. System hardening architecture for safer access to critical business data. **Nigerian Journal of Technology**, v. 34, n. 4, p. 788-792, 2015.

LANDIM, J. O. P. Na trilha da segurança digital: protegendo o conhecimento. **Aracê**, São José dos Pinhais, v. 7, n. 2, p. 8395-8412, 19 fev. 2025.

LIMA, L. S. de. **Análise e gestão de riscos aplicada à segurança da informação**. 2023. Trabalho de Conclusão de Curso. Universidade Tecnológica Federal do Paraná.

MITRE. **ATT&CK® Framework**. Disponível em: <<https://attack.mitre.org/>>. Acesso em: 21 ago. 2025.

MOURAD, A.; LAVERDIÈRE, M.-A.; DEBBABI, M. A high-level aspect-oriented-based framework for software security hardening. **Information Security Journal: A Global Perspective**, v. 17, n. 2, p. 56-74, 2008.

MOREIRA, V.; CUNHA, F. Vulnerabilidades e desafios de segurança em redes IoT: uma revisão sistemática. **Revista Brasileira de Redes de Computadores e Sistemas Distribuídos**, v. 19, n. 1, p. 22-40, 2023.

NIST. National Institute of Standards and Technology. **Framework for improving critical infrastructure cybersecurity**. Version 1.1. Gaithersburg, MD: Nist, 2018. Disponível em: <<https://www.nist.gov/cyberframework>>. Acesso em: 21 ago. 2025.

NIST. National Institute of Standards and Technology. **NIST SP 800-94: Guide to Intrusion Detection and Prevention Systems (IDPS)**. Gaithersburg: Nist, 2007.

NIST. National Institute of Standards and Technology. **NIST SP 800-137: Information Security Continuous Monitoring for Federal Information Systems and Organizations**. Gaithersburg: Nist, 2011.

NUNES, J. et al. SIM-Ciber: uma solução baseada em simulações probabilísticas para quantificação de riscos e impactos de ciberataques utilizando relatórios estatísticos. In: **Simpósio Brasileiro de Segurança da Informação e de Sistemas Computacionais (SBSeg)**. SBC, 2024. p. 570-585.

OLIVEIRA, G. M.; LIMA, R. J. Ataques com inteligência artificial e o impacto na segurança da informação. **Revista de Computação Aplicada**, v. 11, n. 2, p. 45-60, 2024.

OLIVEIRA, M. C. S.; CARELLI, R. de L.; GRILLO, S. Conceito e crítica das plataformas digitais de trabalho. **Revista Direito e Práxis**, v. 11, n. 4, p. 2609-2634, 2020.

RAJAPAKSE, R. N. **Challenges and solutions when adopting DevSecOps: a systematic review**. 2021. Disponível em: <<https://arxiv.org/abs/2103.08266>>. Acesso em: 21 ago. 2025.

SANTOS, H. M.; KRAWSZUK, G. L. Gestão do conhecimento organizacional: tratamento arquivístico para reuso da informação administrativa. **Investigación Bibliotecológica**, v. 34, n. 2, p. 75 - 94, 2020. Disponível em: <https://www.scielo.org.mx/scielo.php?pid=S0187-358X2020000200103&script=sci_abstract&lng=pt>. Acesso em: 21 ago. 2025.

SANTOS, R. dos; SILVA, E. V. Cibersegurança e o modelo ransomware-as-a-service (RaaS): riscos e contramedidas. **Revista de Segurança Cibernética e Defesa**, v. 3, n. 1, p. 17-33, 2023.

SILVA, R. F.; CUNHA, J. A. Arquitetura de segurança em aplicações baseadas em web services. **Holos**, v. 3, p. 15-24, 2005.

SINGH, U. K.; JOSHI, C. Comparative study of information security risk assessment frameworks. **International Journal of Computer Application**, v. 2, n. 8, p. 2250-1797, 2018.

SLAVIN, B. How to prevent sql injection attacks: best practices for secure applications. **DMark Report**, 2025. Disponível em: <<https://dmarcreport.com/blog/how-to-prevent-sql-injection-attacks-best-practices-for-secure-applications/>>. Acesso em: 21 ago. 2025.

SOUZA, M. L.; TORRES, A. F. Segurança em Blockchain: vulnerabilidades em contratos inteligentes e aplicações descentralizadas. **Revista de Sistemas e Computação**, v. 8, n. 1, p. 12-28, 2024.

TAXONOMY. Penetration taxonomy: a systematic review on the penetration process, framework, standards, tools, and scoring methods. **ResearchGate**,

2023. Disponível em: <<https://www.researchgate.net/publication/372124989>>. Acesso em: 21 ago. 2025.

TEIXEIRA, R. S. **Governança de dados:** proposta de um framework conceitual para os órgãos de segurança pública do Distrito Federal. 228 fl. 2023. Dissertação (Mestrado em Governança Tecnologia e Inovação) – Universidade Católica de Brasília (UCB), Brasília/DF, 2023.

UNIÃO EUROPEIA. Regulamento (UE) 2016/679 do Parlamento Europeu e do Conselho, de 27 de abril de 2016. Regulamento Geral sobre a Proteção de Dados - GDPR. **Jornal Oficial da União Europeia**, L 119, 4 maio 2016.

VEERASAMY, N. High-level methodology for carrying out combined red and blue teams. **2009 Second International Conference on Computer and Electrical Engineering**, Dubai, Emirados Árabes Unidos, 2009, p. 416-420. DOI: <<http://dx.doi.org/10.1109/iccee.2009.177>>.

ZHANG, W.; XING, J.; LI, X. Penetration testing for system security: methods and practical approaches. **arXiv**, 2025. Disponível em: <<https://arxiv.org/abs/2505.19174>>. Acesso em: 21 ago. 2025.